

Mediroza General Hospital

Black-Box Penetration Testing Report

Assessment Type: Black-Box Web Application Penetration Test

Target: medirozahospital.com

Prepared By: Amanda Padua

Assessment Period: October 2,2026

1. Executive Summary

As part of my cybersecurity internship, I did a black-box penetration test on the Mediroza General Hospital website. The main goal of the assessment was to look at the website from an external user's perspective and identify security weaknesses that could potentially expose sensitive information. I started by exploring the website and looking at its publicly accessible pages, available functionality, files, and other resources. During the reconnaissance stage, I identified a staff login area, an SQL file, and older files that were accessible within the authorized testing environment.

I then focused on the sensitive documents that were available. I was able to access three password-protected patient PDF reports and downloaded them for further testing. The PDF files were then tested to determine how effective their password protection was. Using Kali Linux, I prepared the files for password testing and used the **Password Checker** and **Hash Checker** provided through the internship portal. The passwords for all three reports were successfully recovered.

I also reviewed the document properties of the three PDF reports. Reports 1 and 2 listed the hospital as the Author, while Report 3 contained different Author information. This showed an inconsistency in the document metadata. In addition to the PDF findings, the discovery of an SQL file and older files during reconnaissance showed that files and resources that are no longer required should be reviewed and properly managed.

Overall, the assessment gave me practical experience in reconnaissance, file discovery, document security testing, password-protection assessment, metadata analysis, and security reporting.

2. Scope and Rules of Engagement

The assessment was conducted within the agreed scope for the Mediroza General Hospital penetration testing exercise.

The target for testing was:

medirozahospital.com

The following rules were followed throughout the assessment:

- **Testing was limited to the target domain only.**
- **No social engineering** was performed.
- **No denial-of-service (DoS) testing** was performed.
- **No testing was conducted outside the agreed scope.**

All testing activities were focused on the authorized target environment. Care was taken to avoid activities that could disrupt services or affect systems outside the agreed scope.

3. Methodology

I followed a step-by-step approach during the assessment. The testing process included:

1. **Reconnaissance** – Exploring the website and identifying publicly accessible pages and functionality.
2. **Enumeration** – Looking for additional accessible areas, files, and resources within the target.
3. **Authentication Testing** – Reviewing the available staff login functionality.
4. **File and Resource Discovery** – Identifying SQL files, older files, and other resources that were accessible within the authorized environment.
5. **Sensitive Document Discovery** – Identifying the patient PDF reports available within the testing environment.
6. **Password Protection Testing** – Assessing how effectively the PDF files were protected by passwords.
7. **Password Recovery Testing** – Using Kali Linux together with the Password Checker and Hash Checker provided through the internship testing portal.
8. **Metadata Review** – Checking the document properties of the PDF reports.
9. **Documentation** – Recording the findings, evidence, potential impact, and recommendations.

This approach allowed me to start with general information gathering and gradually move toward more focused testing of the files and documents that were identified.

4. Website Reconnaissance

I started the assessment by going through the Mediroza General Hospital website to get a better understanding of what was publicly accessible.

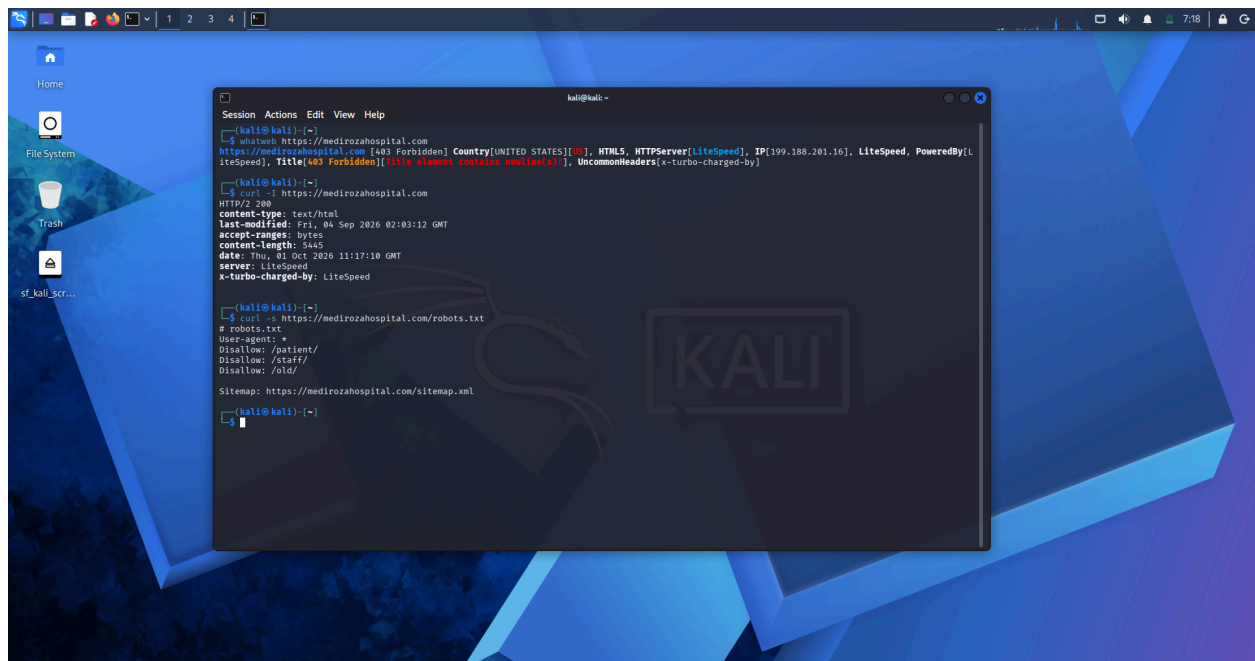
I looked through the main pages and checked the different links and resources available on the website. This helped me understand how the website was organised and what could be seen from an external point of view.

Some of the pages I came across included:

- Home
- About
- Doctors
- Contact
- Staff Login

While exploring the website, I also came across some additional files and resources that were accessible. These included an SQL file and some older files that were still available.

I noted these during the reconnaissance because they could provide useful information about the website and its previous resources. I kept these findings in mind for the next stages of the assessment.

A screenshot of a Kali Linux desktop environment. The desktop background is a blue and purple geometric pattern. On the left side, there are icons for 'Home', 'File System', 'Trash', and 'sf_kali_scr...'. In the center, a terminal window is open, displaying the following commands and output:

```
kali@kali:~$ whatweb https://medirozahospital.com
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES[...]], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.10], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][...], UncommonHeaders[x-turbo-charged-by]

kali@kali:~$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 11:17:10 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

kali@kali:~$ curl -s https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml

kali@kali:~$
```

Figure 1 – Website reconnaissance

5. SQL File Discovery

During the reconnaissance and enumeration stage, I identified an SQL file within the authorized target environment. The file was documented as part of the assessment because an SQL file can potentially contain information related to a website's database structure or previously exported data.

At this stage, the file was treated as an exposed resource and was not modified. Further analysis of the SQL file was included as part of the later stages of the assessment, where relevant to the agreed testing objectives.

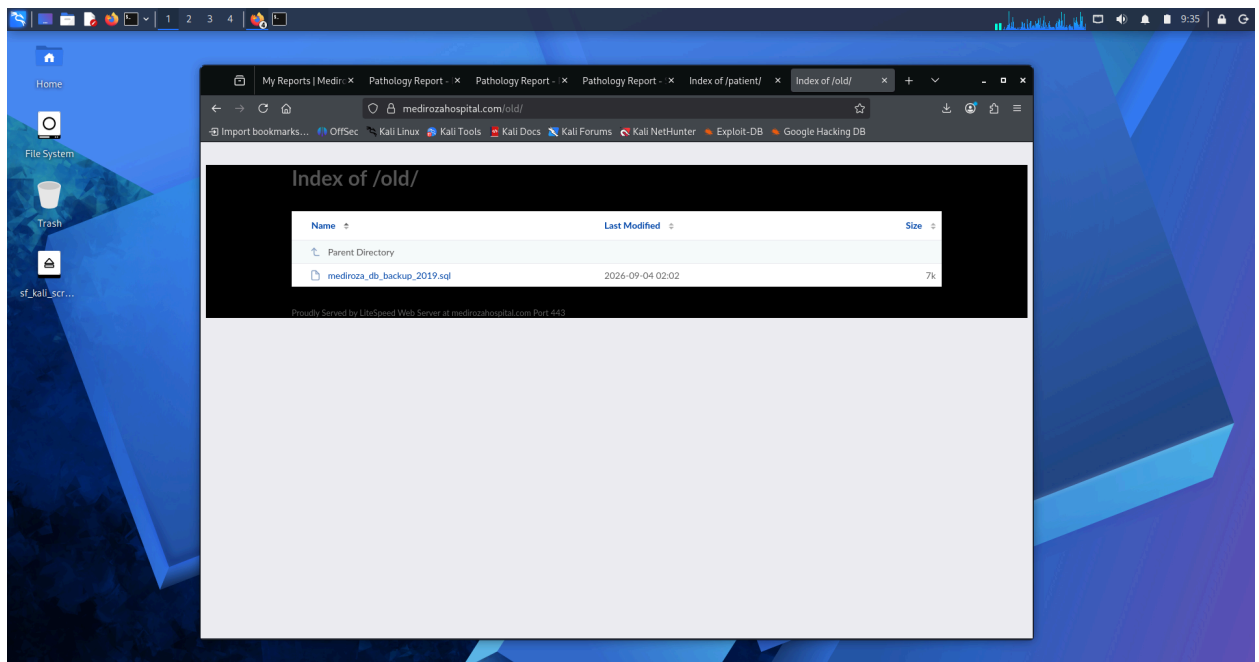


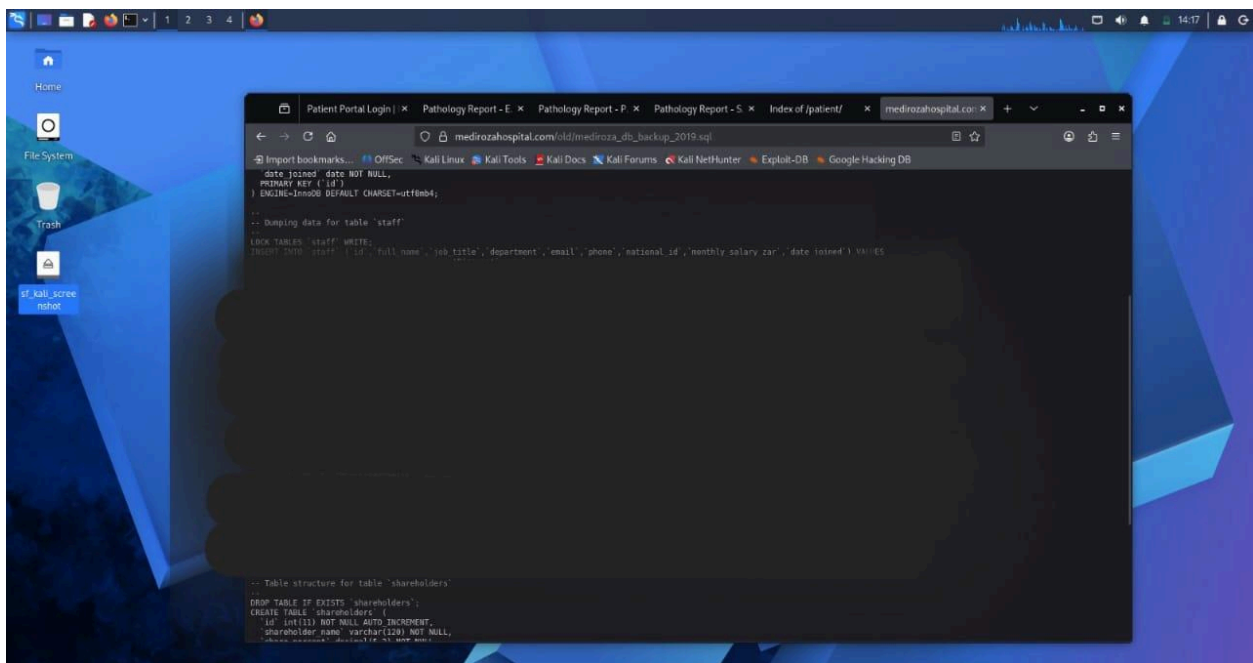
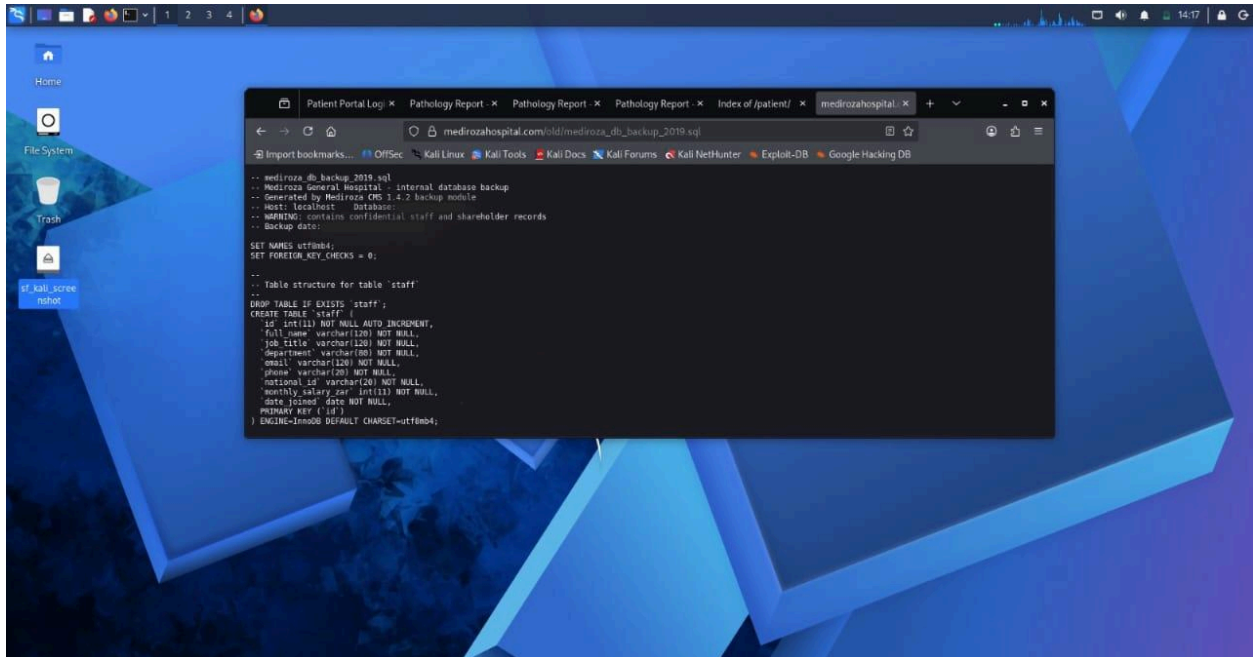
Figure 3 – SQL file identified during testing

6. Discovery of Older Files

While exploring the website, I also identified older files that were still accessible within the target environment. These files appeared to be previous or older resources that were still present on the website.

Keeping old files accessible can create unnecessary exposure because they may contain outdated information, previous versions of pages, configuration details, or other information that is no longer intended to be publicly available.

The files were documented as part of the reconnaissance process.



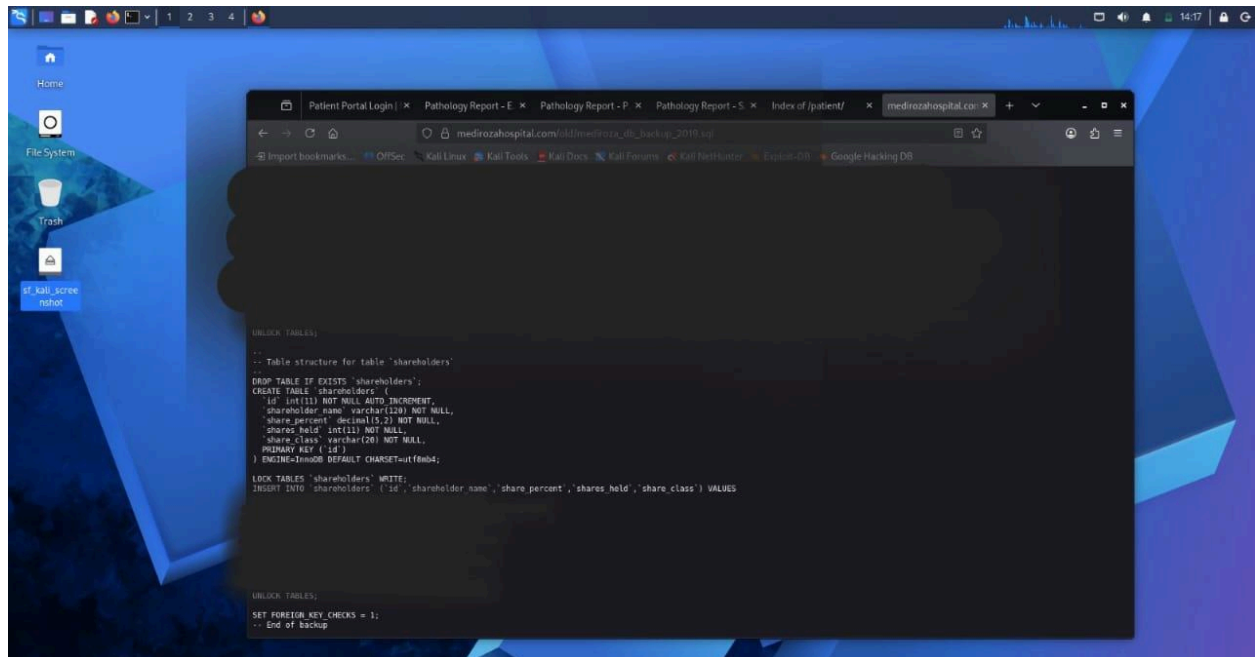


Figure 4 – Older files identified during testing

7. Authentication and Patient Report Discovery

During the assessment, I identified the patient portal and its login page as part of the website reconnaissance. I first performed username enumeration to understand how the login functionality responded to different usernames. I then tested the login form for SQL injection vulnerabilities within the authorized target.

The testing showed that the login mechanism could be bypassed through SQL injection, allowing access to the patient portal without using a valid user password.

After gaining access to the portal, I identified three password-protected patient PDF reports:

- **patient_report_1.pdf**
- **patient_report_2.pdf**
- **patient_report_3.pdf**

I downloaded the three files locally so I could continue the authorized assessment of their password protection without making unnecessary changes to the target system.

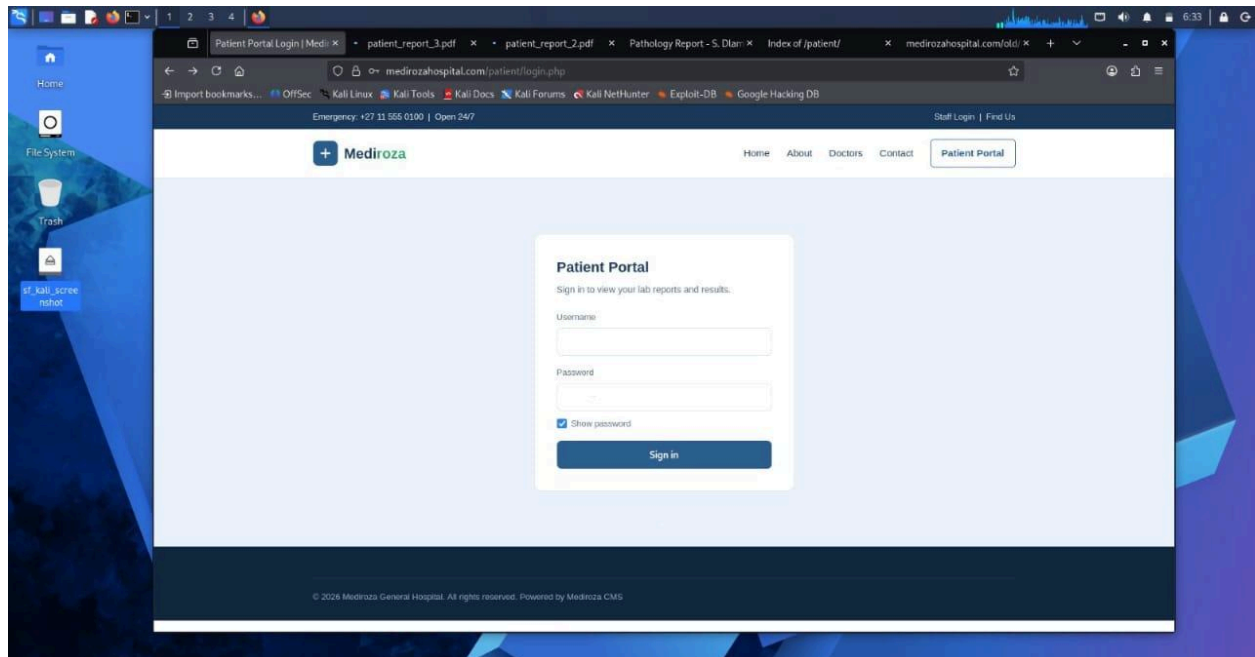


Figure 5 –Patient Log in

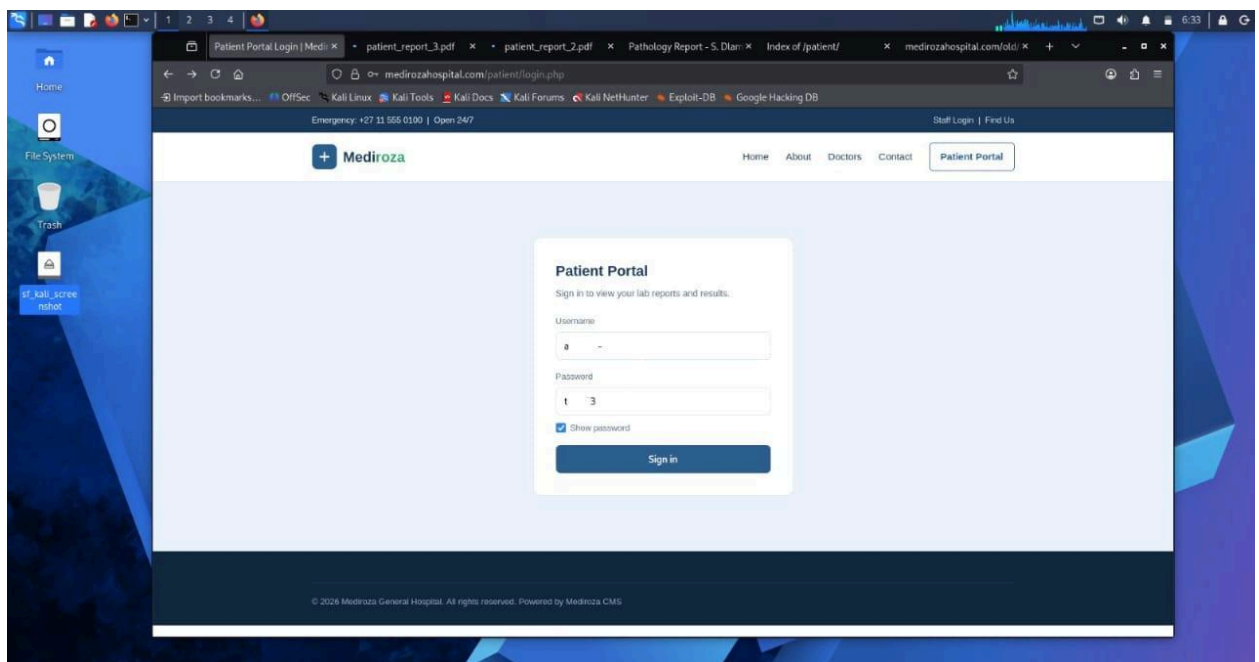


Figure 5 – Username and Password Enumeration

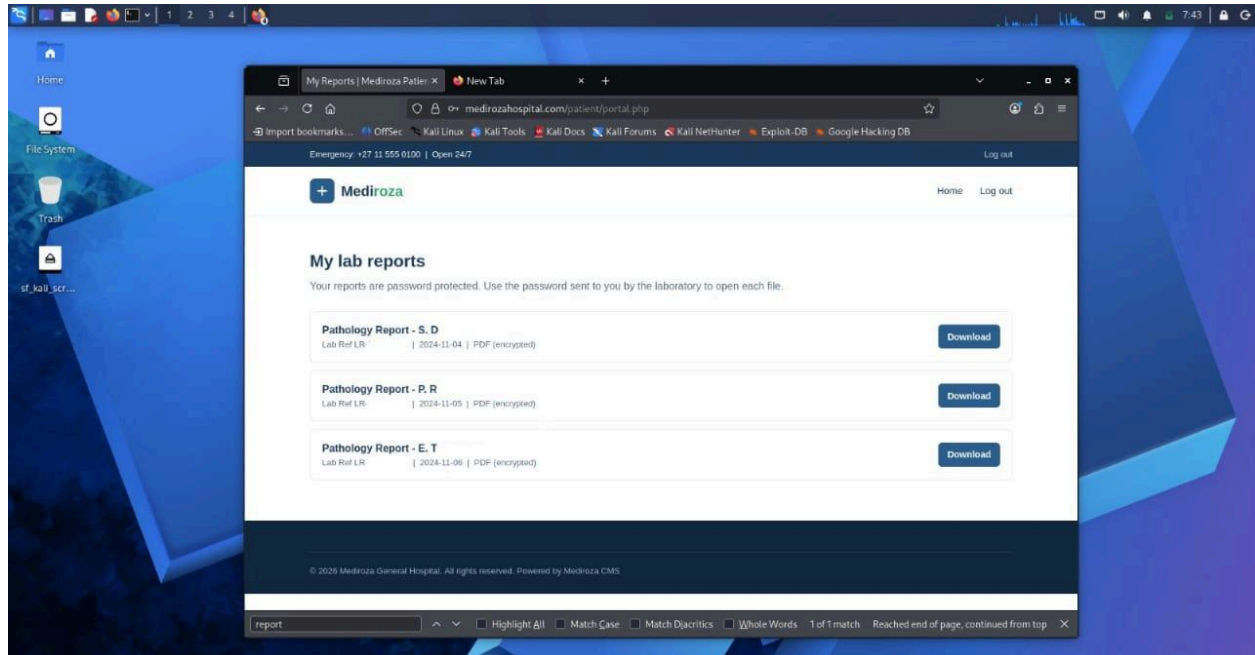


Figure 6 – Patient reports identified during testing

8. PDF Password Protection Testing

After obtaining the three PDF reports, I focused on testing how effective their password protection was. I used the **Kali Linux terminal** to work with the PDF files and prepare the information required for password testing. I then used the **Password Checker** and **Hash Checker** provided through the internship testing portal.

The testing was successful for all three reports. The successful recovery of all three passwords showed that the protection used for these documents could be overcome through password-recovery techniques.

The actual passwords have not been included in this report due to the confidentiality of the hospital reports

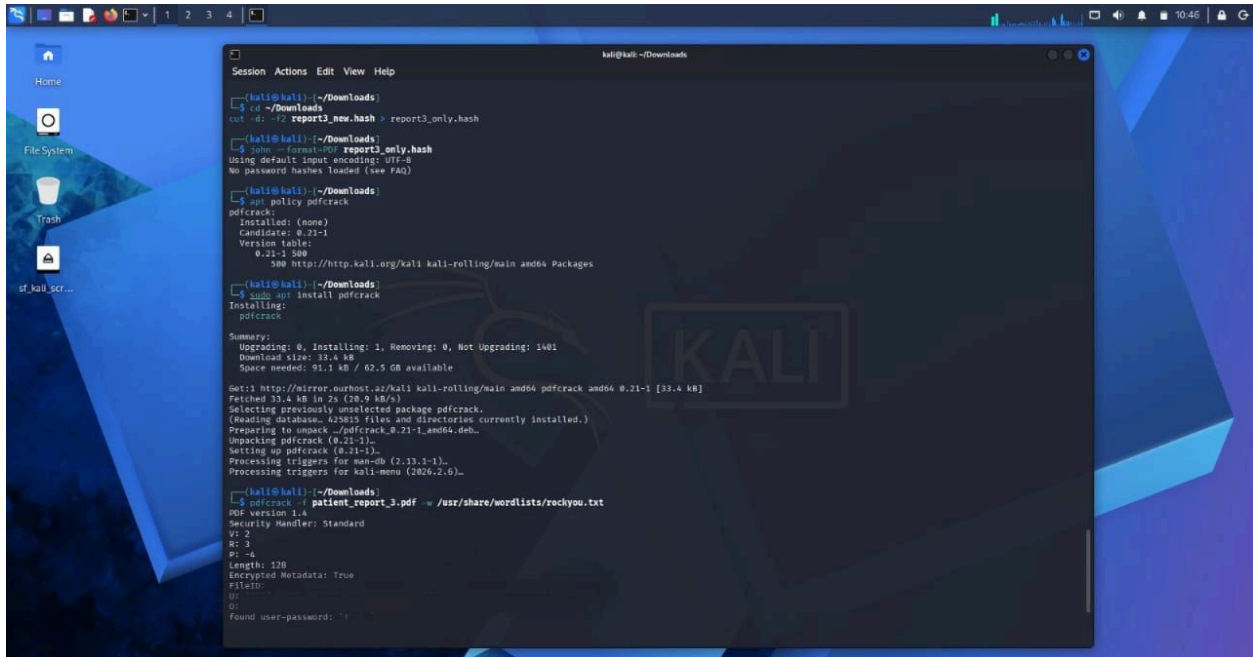
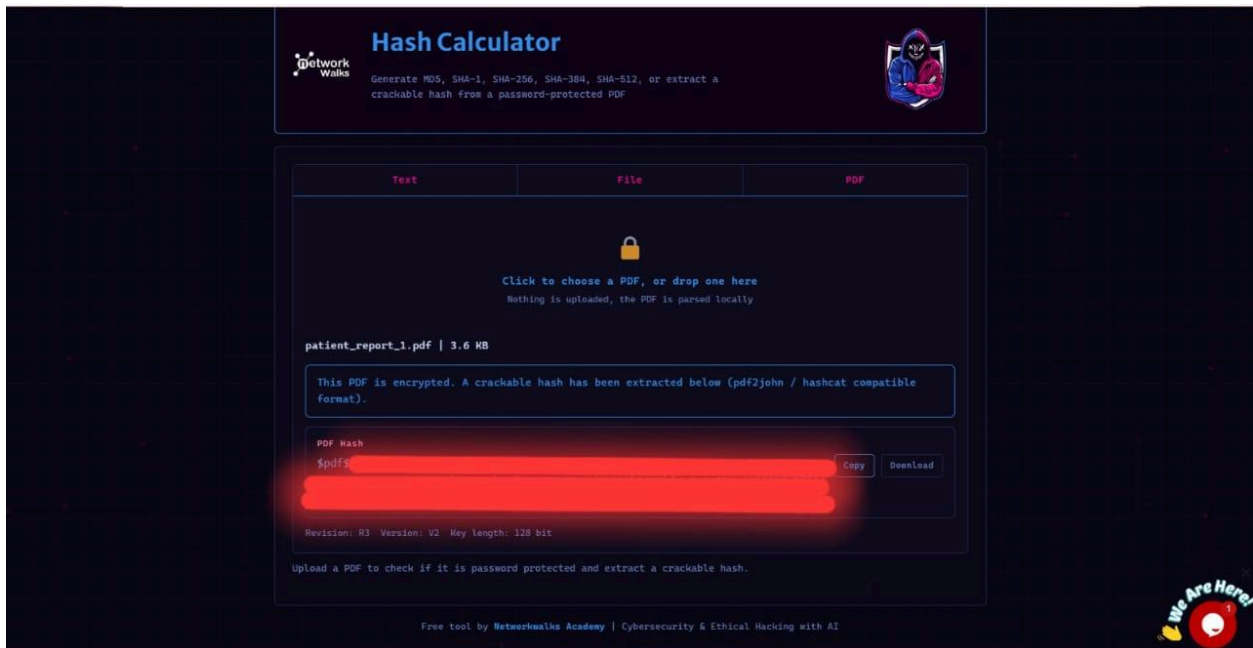


Figure 7 – Password Cracking using Kali Linux



Network Walks

Hash Calculator

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF

Text

File

PDF

Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

patient_report_2.pdf | 3.5 MB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

\$pdf\$[REDACTED]

Copy

Download

Revision: R3 Version: V2 Key length: 128 bit

Upload a PDF to check if it is password protected and extract a crackable hash.

Free tool by NetworkWalks Academy | Cybersecurity & Ethical Hacking with AI

1 Extract the \$pdf\$ hash in the Hash Calculator 2 Paste it below

3 Run the attack, then open your PDF with the password

Tried: 1 / 100

333 pm/s

1%

[*] Loaded wordlist: built-in list (100 entries)

[*] Target: PDF R3 / 128-bit / dictionary attack

[*] Deriving keys with MD5 + RC4 ...

PASSWORD CRACKED SUCCESSFULLY

[REDACTED]

This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

PDF HASH (\$PDF\$...)

[REDACTED]



Figure 8 – Password Cracker / Hash Calculator results

9. Finding MED-001 – Weak PDF Password Protection

Severity: **High**

Description

The three patient reports were protected by passwords, but all three passwords were successfully recovered during the assessment. This indicates that the passwords used to protect the documents were not sufficiently resistant to password-recovery techniques. The issue is particularly important because the files contained sensitive patient information.

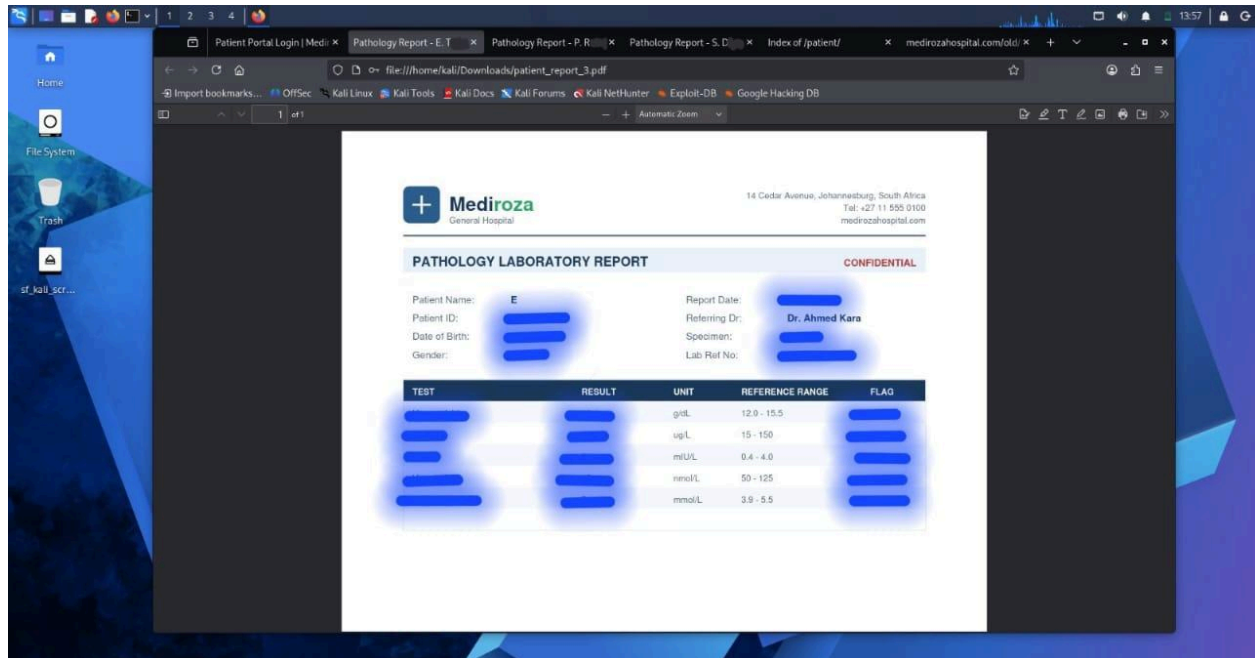
Potential Impact

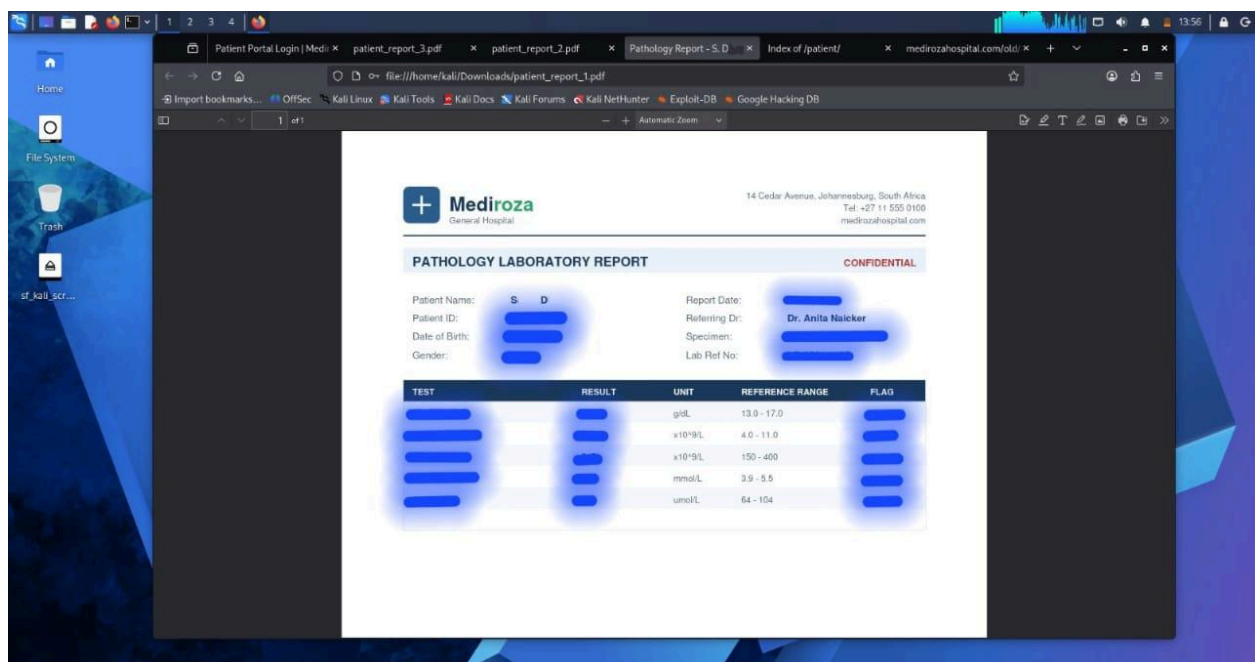
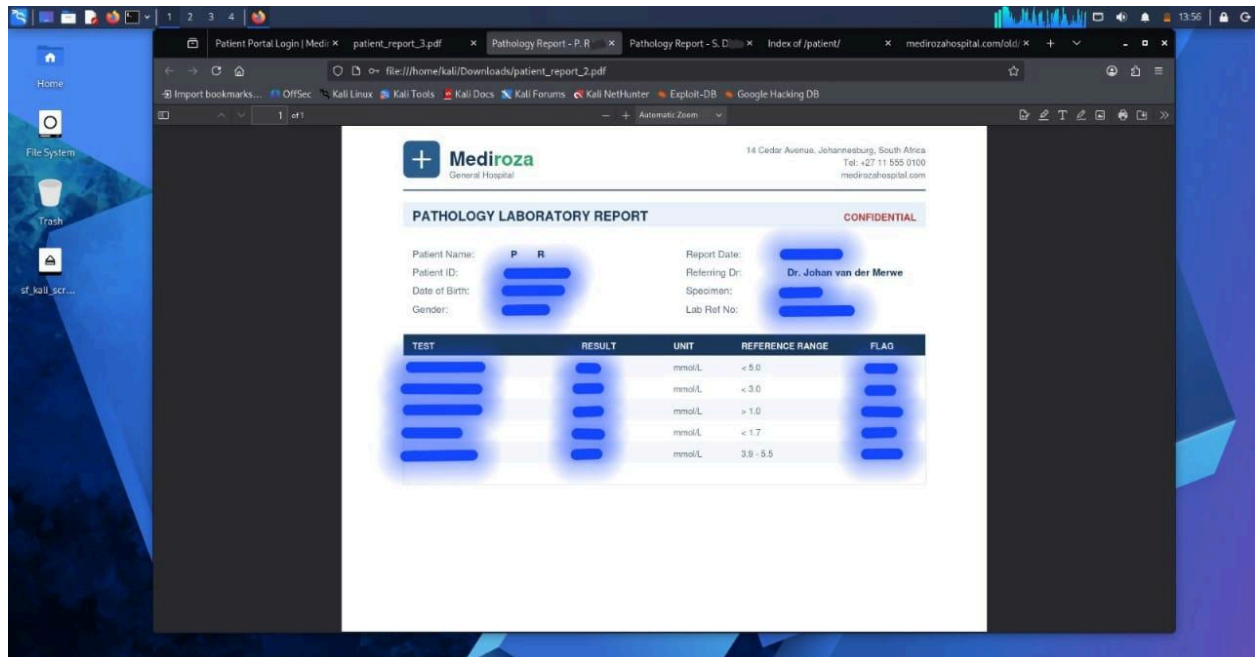
If an unauthorized person obtained one of these PDF files, they could potentially attempt to recover the password and gain access to the information contained in the document. For documents containing patient information, unauthorized access could result in the exposure of sensitive medical data.

Evidence

All three password-protected reports were successfully tested, and their passwords were recovered during the assessment.

Evidence:





Recommendation

The hospital should use strong, unique, and randomly generated passwords when protecting sensitive PDF documents.

Passwords should:

- Be sufficiently long.
- Use a mixture of character types where appropriate.
- Be randomly generated instead of based on predictable information.
- Be unique for sensitive documents.
- Avoid easily guessable personal or organizational information.

For highly sensitive patient information, the hospital should also consider additional access-control and document-security measures instead of relying only on PDF password protection.

10. PDF Metadata Review

After completing the password-protection testing, I reviewed the document properties of all three PDF reports. I specifically checked the **Author** field to see whether the metadata was consistent across the documents.

Reports 1 and 2 listed the hospital as the Author, while Report 3 contained different information in the Author field. This difference does not necessarily confirm who created the document. PDF metadata can be manually entered or inherited from the software or template used to create the file. However, the difference was documented because the three reports appeared to belong to the same hospital environment.

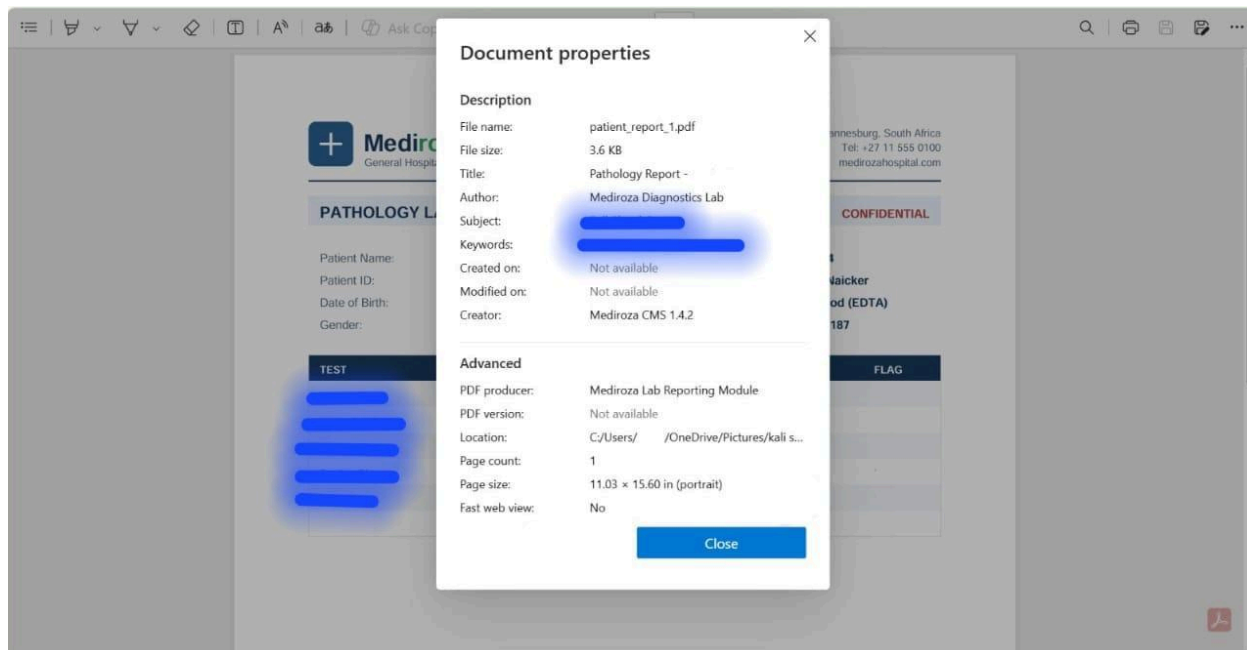


Figure 9 – Report 1 Document Properties

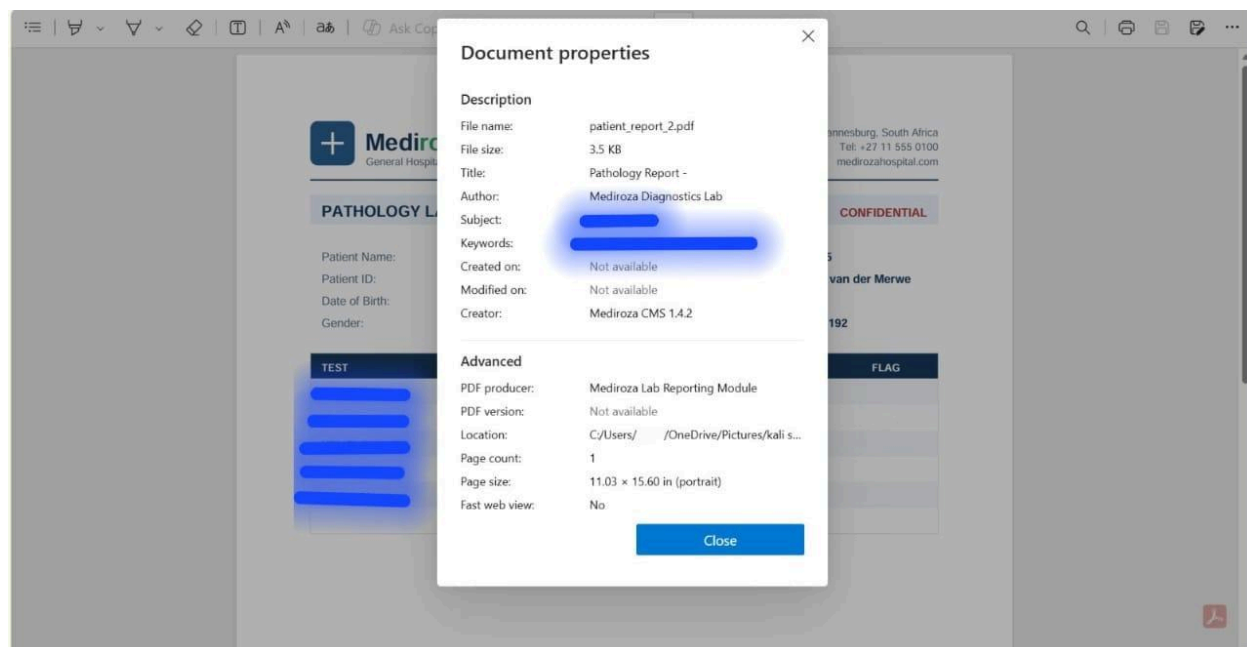


Figure 10 – Report 2 Document Properties

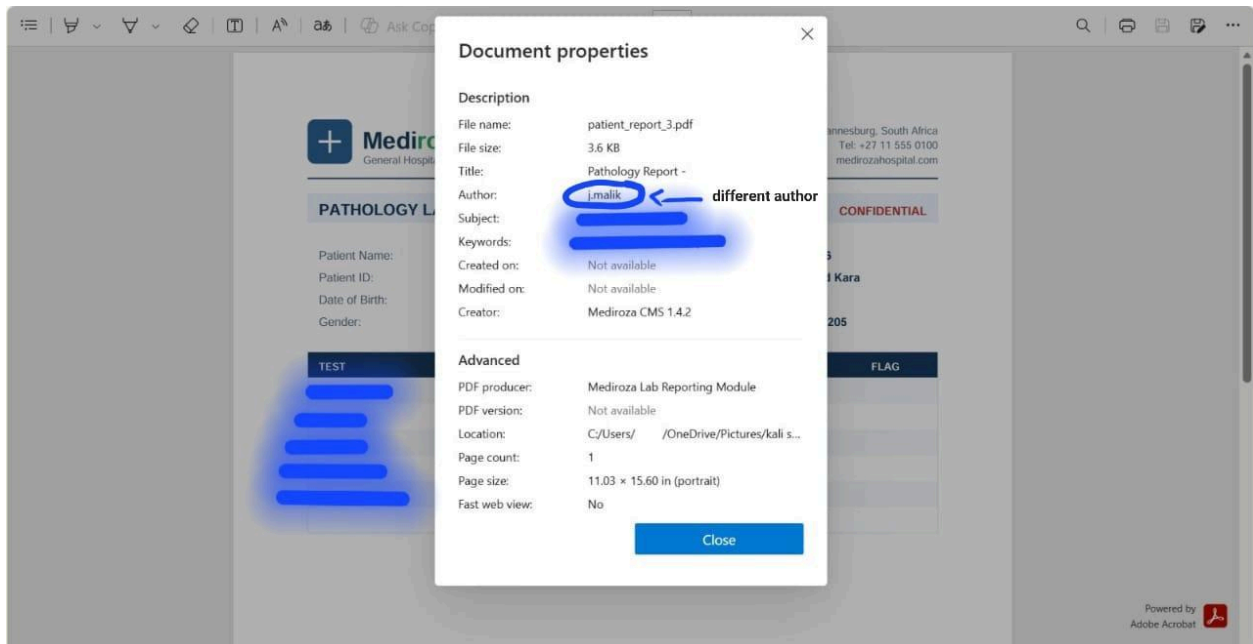


Figure 11 – Report 3 Document Properties

11. Finding MED-002 – Inconsistent PDF Author Metadata

Severity: Low

Description

The Author metadata was not consistent across the three patient reports. Reports 1 and 2 listed the hospital as the Author, while Report 3 contained different Author information.

Potential Impact

PDF metadata can sometimes provide additional information about how a document was created or processed.

Depending on what is stored, metadata may reveal information such as:

- Author names
- Organization names
- Document creators
- Software used to create the document
- Information about the document-generation process

Although this finding does not directly provide access to the hospital's systems, unnecessary metadata can provide additional information to someone examining a sensitive document.

Recommendation

The hospital should review the metadata generated when creating and distributing patient reports. Unnecessary metadata, including Author, Creator, and other document properties, should be removed where appropriate before sensitive documents are distributed. The document-generation process should also be reviewed to ensure that sensitive reports are created using consistent templates and settings.

12. Finding MED-003 – Exposed SQL and Older Files

Severity: Medium

Description

During the reconnaissance and enumeration stages, I identified an SQL file and older files that were accessible within the target environment. The presence of these files was documented because files that are not required for the current website can unintentionally expose information about the application's structure or previous versions. An SQL file can also contain database-related information depending on how it was generated and what data was included in the export.

Potential Impact

Exposed SQL or older files could potentially provide useful information to an attacker, depending on their contents.

For example, they may reveal:

- Database structure
- Table names
- Column names
- Previous application information
- Outdated website content
- Internal names of staffs and shareholders
- Other information that could assist further reconnaissance

The actual impact depends on the contents and sensitivity of the files.

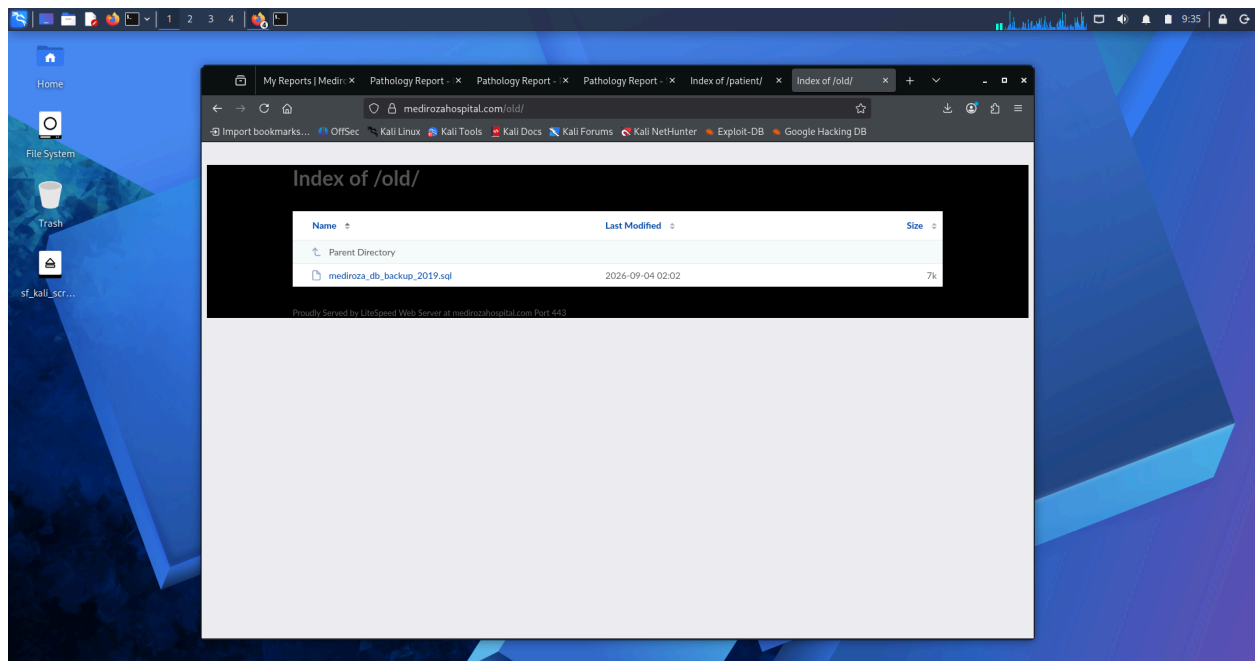
Recommendation

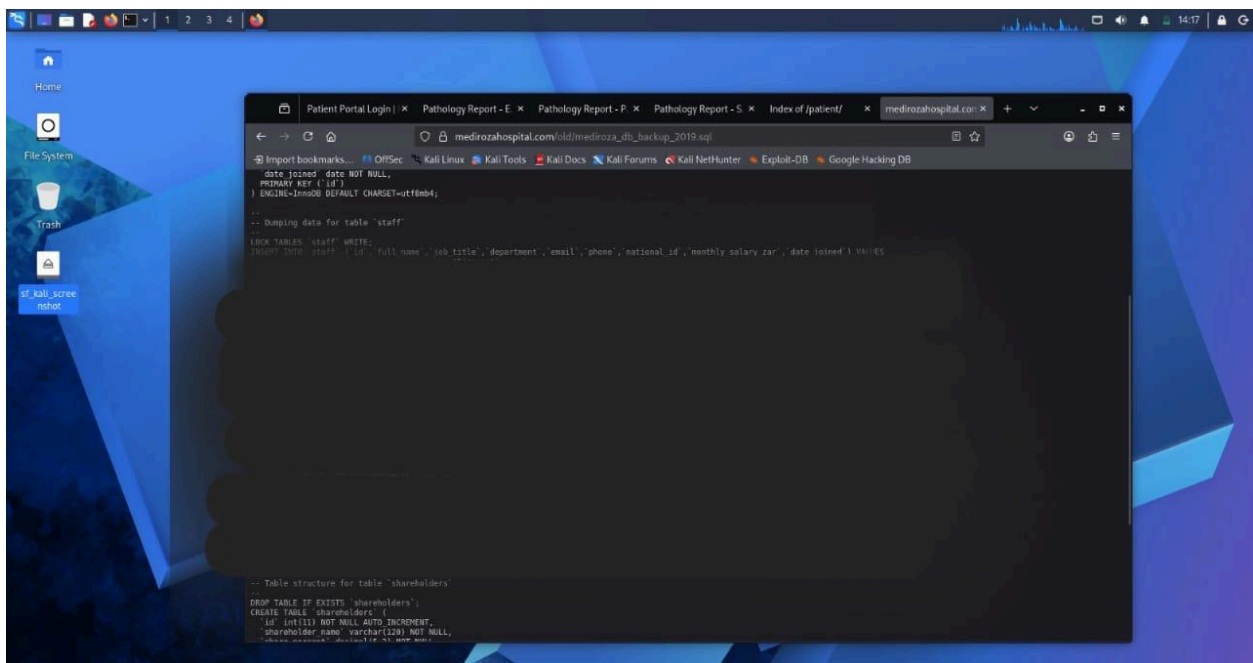
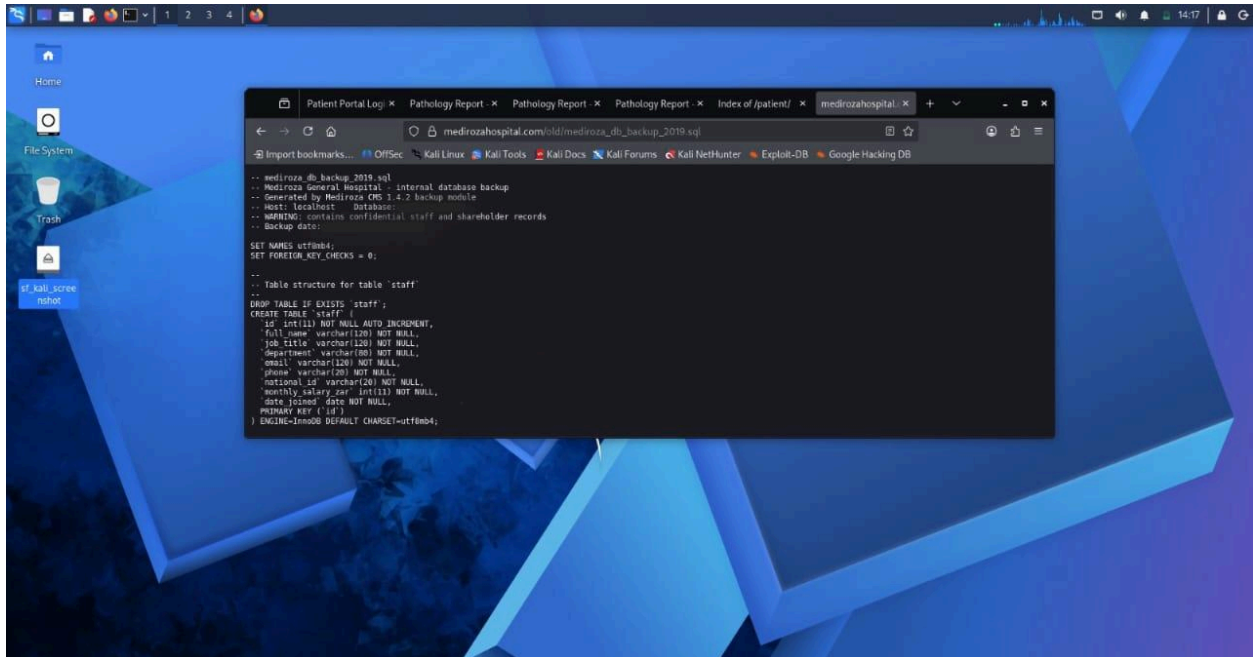
The hospital should review all files stored within the web-accessible directory and remove files that are no longer required.

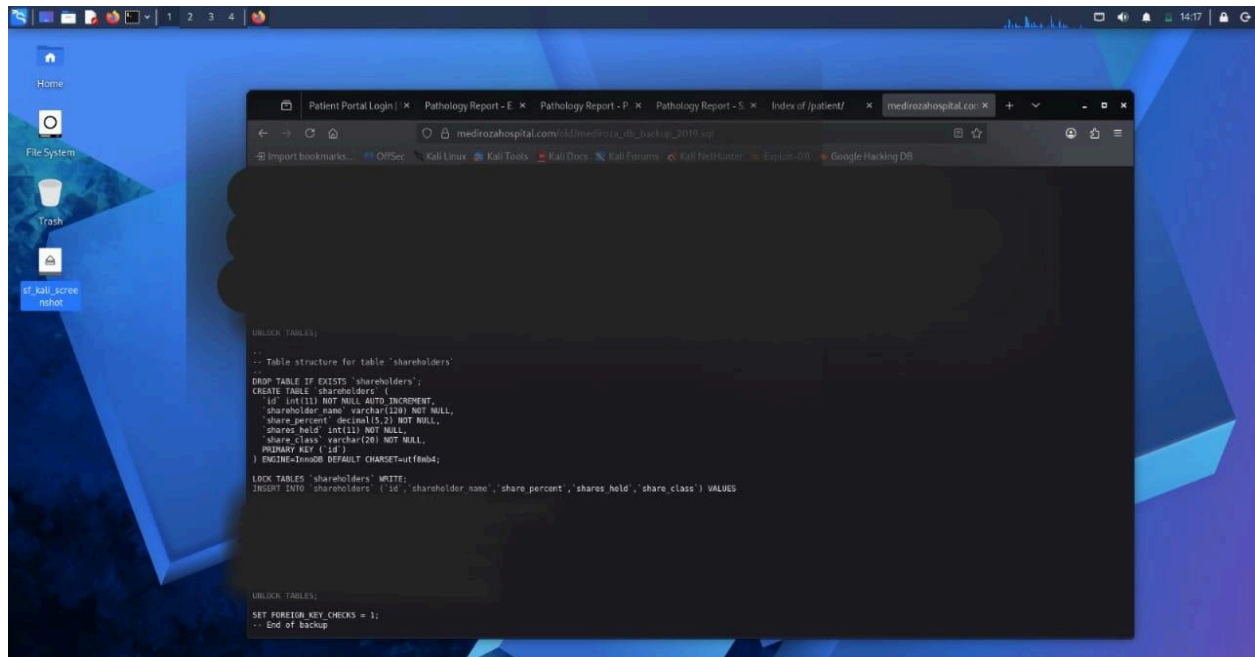
In particular:

- Remove outdated or unused files from the web server.
- Do not store database dumps or SQL exports in publicly accessible directories.
- Review older files before removing them to ensure they are no longer required.
- Restrict access to database-related files.
- Regularly check web directories for forgotten or unnecessary files.

SQL File







13. Tools Used

Tool / Resource	Purpose
Kali Linux	Main cybersecurity testing environment
Firefox	Website reconnaissance and navigation
Kali Linux Terminal	PDF and hash preparation
NETWORKWALKS Password Cracker	Password-security testing
NETWORKWALKS Hash Calculator	Hash and password testing
PDF Document Properties	Metadata review
VirtualBox	Running the Kali Linux environment

14. Findings Summary

The main security concern identified during the assessment was the successful recovery of the passwords protecting all three patient reports. The exposed SQL and older files were also important findings because unnecessary files can provide additional information about a web

application's structure and previous content. The metadata issue was less significant but is still worth addressing to reduce unnecessary information exposure.

ID	Findings	Severity
MED-001	Weak PDF Password Protection	High
MED-002	Inconsistent PDF Author Metadata	Low
MED-003	Exposed SQL and Older Files	Medium

15. Recommendations

Based on the findings from the assessment, I recommend that the hospital consider the following improvements:

1. Strengthen PDF Passwords

Use long, random, and unique passwords for sensitive documents instead of predictable passwords.

2. Use Additional Document Protection

Sensitive patient information should not rely solely on PDF password protection. Additional access controls and secure document-storage methods should also be considered.

3. Review and Remove Unnecessary Files

Regularly review the web server for old, unused, or forgotten files and remove anything that is no longer required.

4. Protect Database-Related Files

SQL files, database exports, and other database-related resources should never be left in publicly accessible web directories unless there is a specific and secure reason for doing so.

5. Review PDF Metadata

Review document properties such as Author and Creator before sensitive reports are distributed.

6. Standardize Document Creation

Use consistent templates and document-generation settings to reduce unexpected metadata exposure.

7. Perform Regular Security Assessments

Regular penetration testing and security reviews can help identify weaknesses before they are discovered or exploited by unauthorized individuals.

16. Conclusion

This assessment gave me the opportunity to examine the Mediroza General Hospital website from an external user's perspective and understand how different types of information could potentially be exposed. During the reconnaissance stage, I identified the website's accessible areas as well as additional resources, including an SQL file and older files. These findings helped me understand the importance of checking not only the main website pages but also files and resources that may have been left accessible.

The main finding was that all three password-protected patient reports had passwords that could be successfully recovered during testing. I used Kali Linux together with the Password Cracker and Hash Calculator provided through the internship testing portal as part of this process. I also reviewed the document properties and noticed that the Author metadata was inconsistent between the reports. While this does not prove who created any particular document, it showed that document metadata should also be considered when handling sensitive files.

Overall, this project gave me practical experience with reconnaissance, enumeration, file discovery, document security testing, password-protection assessment, metadata analysis, evidence collection, and security reporting. It also helped me understand that penetration testing is not only about finding technical vulnerabilities. It is also about looking at what information an organization unintentionally makes accessible and understanding how those small exposures could contribute to a larger security risk.